

Matriz de Evaluación PRAGMATIC Completa — FAICP

29 Indicadores IGM-FAICP calificados según los 9 criterios PRAGMATIC

Escala de puntuación por criterio: 1 = Deficiente · 2 = Aceptable · 3 = Excelente

Interpretación del total: ≥ 21 = Recomendada  | 14–20 = Condicional  | < 14 =

Desestimar/Reformular 

Versión: 1.0 — Abril 2026

Leyenda de Criterios

Código	Criterio	Descripción operativa en contexto FAICP
P	Predictivo	¿El indicador anticipa brechas futuras o solo constata el estado actual?
R	Relevante	¿Es relevante para los objetivos estratégicos de ciberseguridad IA del país o la organización?
A	Accionable	¿Una puntuación baja genera automáticamente un plan de acción claro?
G	Genuino	¿Mide la realidad sin ser susceptible de gaming o maquillaje estadístico?
M	Significativo	¿Es comprensible para la dirección, el CISO y los auditores sin traducción técnica?
Ac	Preciso	¿La escala de medición permite discriminar con suficiente granularidad?
T	Oportuno	¿Puede recogerse a tiempo para influir en decisiones antes de que el riesgo se materialice?
I	Independiente	¿La recogida del dato está libre de conflictos de interés internos?
C	Rentable	¿El coste de medición es proporcional al valor decisional que aporta?

FUNCIÓN GOBERNAR (GV) — 6 Indicadores

IGM-GV-01 — Política formal de ciberseguridad para IA

Marco: NIST IR 8596 GV.OC-04 | **Tipo:** Ordinal 1-5 + checklist

Pregunta QQM: Q-GV-01

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	2	3	2	3	2	3	23	✓ Recomendada

Justificaciones:

- **P=2:** La existencia de la política no predice directamente la ocurrencia de incidentes, pero su ausencia es fuertemente predictiva de brechas de gobernanza. Valor predictivo medio.
- **R=3:** Directamente alineada con EU AI Act Art. 9 (sistema de gestión de riesgos), NIS2 Art. 21 y NIST IR 8596 GV.OC-04. Máxima relevancia regulatoria.
- **A=3:** Una puntuación baja (< 3) activa inmediatamente la necesidad de desarrollar/actualizar la política. El camino de acción es unívoco.
- **G=2:** El riesgo de gaming es moderado (presentar una política no operativa como existente). Mitigation: verificación con checklist de elementos obligatorios y evidencia de aprobación formal.
- **M=3:** "¿Tiene su organización una política de ciberseguridad para IA aprobada por la dirección?" es perfectamente comprensible por cualquier audiencia, incluyendo consejos de administración.
- **Ac=2:** La escala 1-5 con checklist es suficiente para discriminar, pero la diferencia entre un 3 y un 4 puede ser subjetiva sin un checklist muy detallado.
- **T=3:** La política es un documento estático evaluable en cualquier momento. Recogida instantánea.
- **I=2:** Autoevaluación con riesgo de sesgo optimista. Mitigación: evidencia documental requerida (acta de aprobación, fecha, firma de dirección).
- **C=3:** Coste de evaluación mínimo (revisión documental). Valor decisional alto.

Umbral de actuación:

- Puntuación 1: Inexistente → Desarrollar política en < 90 días (obligatorio EU AI Act Art. 9)
- Puntuación 2: Existe pero no está aprobada formalmente → Obtener aprobación de dirección en < 30 días
- Puntuación 3: Aprobada pero > 24 meses sin revisión → Revisar y actualizar en < 60 días
- Puntuación 4: Vigente y actualizada pero sin elementos IA específicos → Añadir sección IA en < 30 días
- Puntuación 5: Política completa, aprobada, vigente, con todos los elementos NIST IR 8596 GV.OC-04

IGM-GV-02 — Mapa de dependencias de infraestructura IA

Marco: NIST IR 8596 GV.OC-05 | **Tipo:** Ordinal 1-5 + inventario de proveedores

Pregunta QQM: Q-GV-02

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	2	2	2	2	21	✓ Recomendada

Justificaciones:

- **P=3:** El conocimiento de dependencias es altamente predictivo de la superficie de ataque real. Las organizaciones sin mapa de dependencias tienen superficies de ataque no cuantificables.
- **R=3:** Critical para NIS2 Art. 21.2.a (gestión de riesgos de la cadena de suministro) y EU AI Act Art. 53 (obligaciones proveedores de IA de propósito general).
- **A=3:** Una brecha en el mapa de dependencias activa inmediatamente un proceso de descubrimiento y catalogación.
- **G=2:** Difícil de gaming pero también difícil de verificar externamente sin acceso a los sistemas internos.
- **M=2:** El concepto de "dependencia de infraestructura IA" puede ser abstracto para audiencias no técnicas. Requiere traducción.
- **Ac=2:** La granularidad de la escala 1-5 puede ser insuficiente para organizaciones con arquitecturas IA complejas.
- **T=2:** El mapa de dependencias puede desactualizarse rápidamente en entornos de adopción IA acelerada (Shadow AI). Frecuencia de actualización recomendada: trimestral.
- **I=2:** La recogida interna tiene riesgo de omisiones no intencionadas (dependencias desconocidas, Shadow AI).
- **C=2:** El coste de construir y mantener un mapa de dependencias completo puede ser significativo para organizaciones grandes.

Umbral de actuación:

- Puntuación 1: Sin mapa → Iniciar ejercicio de descubrimiento urgente (CMDB + AI-BOM)
- Puntuación 2: Mapa parcial (< 50% de sistemas) → Plan de completitud en 90 días
- Puntuación 3: Mapa completo pero sin actualización periódica → Establecer proceso trimestral
- Puntuación 4: Mapa actualizado pero sin clasificación de criticidad → Añadir clasificación de impacto
- Puntuación 5: Mapa completo, actualizado trimestralmente, con clasificación y análisis de impacto en cascada

IGM-GV-03 — Riesgos IA adversarial en formación de RRHH

Marcos: NIST IR 8596 GV.RR-04 | **Tipo:** Ordinal 1-5 + cobertura temática

Pregunta GQM: Q-GV-03

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	3	2	3	2	2	23	✓ Recomendada

Justificaciones:

- **P=3:** El nivel de concienciación del personal sobre IA adversarial es uno de los mejores predictores de la resistencia organizativa al phishing LLM y deepfakes, que representan el 80%+ de la ingeniería social IA en 2025.
- **R=3:** EU AI Act Art. 4 establece la obligación de "alfabetización en IA" para el personal que opera sistemas de IA. NIS2 Art. 21.2.g requiere formación específica en ciberseguridad.
- **A=3:** Puntuación baja genera inmediatamente un plan de formación con temas específicos (ingeniería social IA, reconocimiento de deepfakes, uso seguro de GenAI).
- **G=2:** El riesgo de gaming (registrar formaciones superficiales como completas) es real. Mitigación: verificar cobertura temática con contenidos, no solo horas de formación.
- **M=3:** "¿Su personal recibe formación sobre phishing con IA y deepfakes?" es perfectamente comprensible.
- **Ac=2:** La diferencia entre un programa "bueno" y uno "muy bueno" de formación es difícil de objetivar.
- **T=3:** Las estadísticas de finalización de formaciones son inmediatamente disponibles en la mayoría de LMS.
- **I=2:** La autoevaluación puede sobrestimar la cobertura real. Verificación recomendada: examen de conocimientos post-formación.
- **C=2:** El coste de desarrollo de contenidos de formación IA adversarial puede ser significativo para organizaciones pequeñas.

Temas mínimos obligatorios (Puntuación 5):

1. Reconocimiento de phishing asistido por IA (syntaxis, personalización hiperprecisa)
2. Identificación de deepfakes de audio y vídeo en comunicaciones ejecutivas
3. Políticas de uso seguro y aceptable de herramientas GenAI (Shadow AI)
4. Procedimientos de reporte de incidentes relacionados con IA
5. Gestión segura de prompts e instrucciones para sistemas IA internos

IGM-GV-04 — Evaluación sistemática de proveedores de IA

Marcos: NIST IR 8596 GV.SC-07 | **Tipo:** Ordinal 1-5 + periodicidad

Pregunta GQM: Q-GV-04

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	2	2	2	2	21	✓ Recomendada

Justificaciones:

- **P=3:** Las brechas de cadena de suministro en IA (LLM03 OWASP) son de alta probabilidad y el control preventivo de evaluación de proveedores es directamente predictivo de la resistencia a este vector.
- **R=3:** NIS2 Art. 21.2.d (seguridad en la cadena de suministro), EU AI Act Art. 25 (obligaciones de los desplegados) y NIST IR 8596 GV.SC-07.
- **A=3:** Una evaluación insuficiente de un proveedor concreto genera una acción de remediación directa (solicitar controles adicionales, añadir cláusulas contractuales, cambiar proveedor).
- **G=2:** El gaming es posible (realizar evaluaciones superficiales). Mitigación: plantilla de evaluación estandarizada con preguntas específicas sobre seguridad de datos de entrenamiento, pruebas adversariales y certificaciones.
- **M=2:** El concepto de "evaluación de riesgos de proveedor de IA" requiere explicación para audiencias de negocio.
- **Ac=2:** La escala 1-5 sobre la periodicidad y profundidad de evaluación puede ser subjetiva.
- **T=2:** Las evaluaciones de proveedores son procesos prolongados; el indicador refleja el estado en un punto temporal, no la dinámica.
- **I=2:** La evaluación de proveedores puede tener sesgos relacionales (proveedores estratégicos evaluados más benignamente).
- **C=2:** El proceso de evaluación de proveedores IA tiene un coste significativo si se hace con profundidad.

IGM-GV-05 — Función de gobernanza de IA (comité/rol)

Marco: AI RMF GOVERN 1.1 | **Tipo:** Binario + calidad (1-5)

Pregunta GQM: Q-GV-05

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	3	3	2	3	3	3	25	✓ Recomendada

Justificaciones:

- **P=2:** La existencia de la función predice mejores outcomes pero no garantiza que se utilice efectivamente.
- **R=3:** NIST AI RMF GOVERN 1.1 identifica la "función de gobernanza de IA" como el control de

gobernanza más crítico. EU AI Act requiere implícitamente funciones de supervisión (Arts. 9, 26, 27).

- **A=3:** Ausencia de función → crear el rol/comité inmediatamente. Claridad total en la acción requerida.
- **G=3:** Es relativamente difícil de falsificar: la existencia de un comité con reuniones documentadas y presupuesto asignado es verificable.
- **M=3:** "¿Quién en su organización es responsable de la gobernanza de IA?" es perfectamente comprensible.
- **Ac=2:** La calidad del mandato y el presupuesto del comité son difíciles de objetivar con una escala simple.
- **T=3:** El dato es estático y verificable en cualquier momento.
- **I=3:** El dato es verificable por terceros (organigramas, actas de reunión, presupuestos).
- **C=3:** La evaluación tiene un coste mínimo (verificación documental).

IGM-GV-06 — Registro y clasificación EU AI Act

Marco: EU AI Act Art. 49 | **Tipo:** Ordinal 1-5 + completitud del registro

Pregunta QGM: Q-GV-06

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	3	2	3	2	2	2	22	 Recomendación

Justificaciones:

- **P=2:** El registro por sí mismo no predice incidentes, pero su ausencia indica desconocimiento regulatorio que predice sanciones y brechas de control.
- **R=3:** Obligación legal directa del EU AI Act Art. 49 para proveedores y Art. 27 para desplegados. Sanciones hasta 30M€ o 6% del volumen global.
- **A=3:** Sistema no registrado → registrar inmediatamente en EUDB. Acción inequívoca.
- **G=3:** El registro en EUDB es verificable externamente. Difícil de manipular.
- **M=2:** La clasificación de riesgo del EU AI Act (prohibido, alto riesgo, riesgo limitado, mínimo) requiere familiaridad con la normativa para ser comprensible.
- **Ac=3:** La escala de completitud del registro (qué porcentaje de sistemas están registrados y correctamente clasificados) es objetiva y granular.
- **T=2:** El registro requiere análisis jurídico previo que puede ser lento.
- **I=2:** La clasificación puede hacerse de forma optimista (clasificar sistemas de alto riesgo como de riesgo limitado para evitar obligaciones).
- **C=2:** El proceso de clasificación y registro puede requerir asesoría jurídica especializada.

FUNCIÓN IDENTIFICAR (ID) — 5 Indicadores

IGM-ID-01 — AI-BOM: Inventario completo de sistemas de IA

Marco: NIST IR 8596 ID.AM-07 (Tier 1) | **Tipo:** Ordinal 1-5 + exhaustividad del inventario

Pregunta GQM: Q-ID-01

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	3	2	2	2	22	 Recomendada

Justificaciones:

- **P=3:** El indicador Tier 1 más predictivo del NIST IR 8596. Sin inventario de sistemas IA, es imposible proteger, detectar o responder a ataques contra ellos. "No puedes proteger lo que no sabes que existe."
- **R=3:** NIST IR 8596 ID.AM-07 (Tier 1), EU AI Act Arts. 11-13 (documentación técnica), NIS2 Art. 21.2.a.
- **A=3:** Sistema no inventariado → descubrir, catalogar, clasificar. Proceso de acción claro.
- **G=2:** El Shadow AI es el principal riesgo para la genuinidad de este indicador: el 70% de organizaciones españolas no detecta IA no controlada. Mitigación: herramientas de descubrimiento automático de APIs y modelos (Netskope, Wiz, Prisma Cloud).
- **M=2:** El concepto de "AI Bill of Materials" puede requerir explicación a audiencias no técnicas. Analogía útil: "el inventario de ingredientes del sistema de IA".
- **Ac=3:** La exhaustividad del inventario puede medirse objetivamente (% de sistemas conocidos vs. descubiertos por herramientas automáticas).
- **T=2:** El inventario puede desactualizarse rápidamente (nuevas integraciones, Shadow AI). Requiere actualización continua o frecuente.
- **I=2:** El equipo interno puede no ser consciente de todas las implementaciones de IA (especialmente las de otros departamentos).
- **C=2:** Las herramientas de descubrimiento automático de IA tienen un coste de implementación y mantenimiento significativo.

Elementos mínimos del AI-BOM (Puntuación 5):

- Identificador único del sistema de IA
- Tipo de modelo (LLM, clasificador, sistema de recomendación, etc.)
- Proveedor y versión del modelo base
- Datos de entrenamiento (origen, fecha, licencia)
- Datos de fine-tuning (si aplica)
- APIs externas consumidas
- Nivel de riesgo EU AI Act
- Datos personales procesados (RGPD relevante)

- Propietario técnico y propietario de negocio
- Fecha de última evaluación de seguridad

IGM-ID-02 — Evaluación de vulnerabilidades específicas IA

Marco: OWASP LLM Top 10 2025 | **Tipo:** Ordinal 1-5 + cobertura LLM01-LLM10

Pregunta GQM: Q-ID-02

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	3	2	2	2	22	✓ Recomendada

Umbral de cobertura:

- Puntuación 1: Sin evaluaciones específicas IA
- Puntuación 2: Evaluación de 1-3 categorías OWASP LLM (solo las obvias: LLM01, LLM02)
- Puntuación 3: Evaluación de 4-6 categorías con metodología documentada
- Puntuación 4: Evaluación de 7-9 categorías con frecuencia semestral
- Puntuación 5: Evaluación de las 10 categorías + agéntica, frecuencia trimestral, integrada en CI/CD

IGM-ID-03 — Consumo de inteligencia de amenazas IA adversarial

Marco: MITRE ATLAS v5.5 | **Tipo:** Ordinal 1-5 + fuentes CTI consumidas

Pregunta GQM: Q-ID-03

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	2	2	2	2	2	3	2	2	20	⚠ Condicional

Nota de mejora: La condicionabilidad se debe a que el mercado de CTI específico para IA adversarial aún es incipiente y los feeds disponibles son heterogéneos. El indicador mejorará a "Recomendado" cuando los feeds MITRE ATLAS maduren en 2026-2027.

IGM-ID-04 — Modelado de velocidad de ataques IA en gestión de riesgos

Marco: NIST IR 8596 ID.RA-04 | **Tipo:** Ordinal 4 niveles

Pregunta GQM: Q-ID-04

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	2	2	2	2	3	2	2	21	✓ Recomendada

Niveles de medición:

- Nivel 1: La velocidad de ataque IA no se considera en los modelos de riesgo
- Nivel 2: Se reconoce la velocidad mayor pero no se cuantifica en el modelo de riesgo
- Nivel 3: Se incorpora la velocidad de ataque IA en el cálculo de ventanas de exposición
- Nivel 4: El modelo de riesgo incluye escenarios específicos de ataque automatizado a velocidad de máquina (36K scans/s) con cálculos de impacto actualizados

IGM-ID-05 — Análisis de riesgos de cadena de suministro IA

Marco: NIST IR 8596 ID.SC-02; OWASP LLM03 | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-ID-05

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	2	2	2	2	21	✓ Recomendada

FUNCIÓN PROTEGER (PR) — 6 Indicadores

IGM-PR-01 — IAM específico para sistemas y agentes de IA

Marco: NIST IR 8596 PR.AA-01 (Tier 1) | **Tipo:** Ordinal 1-5 + controles implementados

Pregunta GQM: Q-PR-01

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	2	2	2	3	22	✓ Recomendada

Controles mínimos (Puntuación 5):

- Identidades únicas para cada sistema/agente de IA (no credenciales compartidas)
- MFA o equivalente para acceso a interfaces de administración de modelos
- Rotación automática de credenciales de APIs de IA

- Segregación de entornos (desarrollo, pruebas, producción) con controles de acceso diferenciados
- Registro de auditoría completo de accesos e invocaciones de sistemas IA

IGM-PR-02 — Menor privilegio en agentes IA autónomos

Marco: NIST IR 8596 PR.AA-05; OWASP LLM06 | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-PR-02

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	3	2	2	2	2	22	✓ Recomendada

Nota crítica: Este es el indicador más directamente relevante para la amenaza LLM06 (Excessive Agency) del OWASP Top 10, que en la versión 2025 aparece en posición 6. Los agentes IA con acceso no acotado a herramientas externas (envío de emails, ejecución de código, acceso a bases de datos) representan el vector de mayor impacto potencial en 2026.

IGM-PR-03 — Cobertura y frecuencia de formación en amenazas IA

Marco: EU AI Act Art. 4 (Alfabetización IA) | **Tipo:** Ordinal 5 niveles

Pregunta GQM: Q-PR-03

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	3	2	3	2	2	23	✓ Recomendada

Niveles:

- 1: Sin formación sobre amenazas IA
- 2: Formación anual genérica de sensibilización ($\leq 1h$)
- 3: Formación semestral con módulos específicos de IA adversarial (phishing LLM, deepfakes)
- 4: Formación trimestral, diferenciada por rol, con simulaciones de ataques reales
- 5: Programa continuo, diferenciado por rol, con simulaciones automatizadas, métricas de click rate, y módulos avanzados para equipos técnicos (ejercicios red team IA)

IGM-PR-04 — Protección de datos de entrenamiento e inferencia

Marco: EU AI Act Art. 10; OWASP LLM02 | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-PR-04

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	2	2	2	2	21	✓ Recomendada

IGM-PR-05 — Control de versiones y gestión MLOps de modelos

Marco: NIST IR 8596 PR.PS-01 | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-PR-05

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	3	2	2	2	3	2	22	✓ Recomendada

Nota: El criterio **G=3** (Genuino) es excepcionalmente alto porque el control de versiones de modelos deja rastros técnicos verificables (repositorios, hashes, fechas de commit) que son difíciles de falsificar.

IGM-PR-06 — Evaluación y control de agencia excesiva (LLM06)

Marco: OWASP LLM06; EU AI Act Art. 14 | **Tipo:** Ordinal 5 categorías

Pregunta GQM: Q-PR-06

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	2	2	2	2	21	✓ Recomendada

Categorías de evaluación:

- A: Agentes sin restricciones de herramientas documentadas (más peligroso)
- B: Restricciones documentadas pero no implementadas técnicamente
- C: Restricciones técnicas pero sin monitorización de invocaciones
- D: Restricciones técnicas con monitorización y alertas de anomalías
- E: Restricciones técnicas, monitorización, alertas y revisión humana para acciones de alto impacto (más seguro)

FUNCIÓN DETECTAR (DE) — 5 Indicadores

IGM-DE-01 — Monitorización de APIs de IA externas

Marco: NIST IR 8596 DE.CM-06; OWASP LLM10 | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-DE-01

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	3	3	2	2	23	✓ Recomendada

Justificaciones clave:

- **T=3:** Los logs de tráfico de red/API están disponibles en tiempo real; la monitorización puede ser continua.
- **Ac=3:** El volumen de llamadas a APIs, latencia, errores y datos transferidos son métricas altamente objetivas y granulares.

IGM-DE-02 — Monitorización en tiempo de ejecución de sistemas IA

Marco: NIST IR 8596 DE.CM-09 (Tier 1) | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-DE-02

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	3	3	2	2	23	✓ Recomendada

Dimensiones de monitorización (Puntuación 5):

- Inputs al modelo (análisis de distribución para detección de prompt injection)
- Outputs del modelo (análisis de contenido, toxicidad, hallucination rate)
- Comportamiento del agente (herramientas invocadas, frecuencia, secuencias anómalas)
- Consumo de recursos (tokens, coste por inferencia — detección LLM10)
- Latencia y disponibilidad (baseline + alertas de degradación)

IGM-DE-03 — Frecuencia y método de evaluación de model drift

Marco: EU AI Act Art. 72.1; AI RMF MEASURE 2.6 | **Tipo:** Ordinal 6 niveles

Pregunta GQM: Q-DE-03

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	3	3	2	2	23	✓ Recomendada

Niveles:

- 0: Sin evaluación de drift
- 1: Evaluación ad-hoc (solo cuando hay quejas o evidencia de problemas)
- 2: Evaluación anual planificada
- 3: Evaluación semestral con métricas de rendimiento predefinidas
- 4: Evaluación mensual con dashboard automatizado de métricas de drift
- 5: Monitorización continua automatizada con alertas ante umbrales de drift predefinidos y protocolo de reentrenamiento automático

IGM-DE-04 — Capacidades del SOC para amenazas IA adversariales

Marco: MITRE ATLAS v5.5 | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-DE-04

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	2	2	2	2	2	2	20	⚠ Condicional

Nota de mejora: La condicionabilidad refleja que muy pocos SOC's tienen actualmente reglas de correlación específicas para las tácticas MITRE ATLAS. El indicador pasará a "Recomendado" cuando la madurez del mercado lo permita (estimado 2027). Para 2025-2026, el objetivo realista es Puntuación 2-3 para la mayoría de organizaciones.

IGM-DE-05 — Controles de detección de prompt injection

Marco: OWASP LLM01; NIST IR 8596 DE.CM-03 | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-DE-05

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	2	2	2	3	2	2	22	✓ Recomendada

FUNCIÓN RESPONDER (RS) — 4 Indicadores

IGM-RS-01 — Playbooks de respuesta específicos para IA

Marco: NIST IR 8596 RS.MA-01 (Tier 1) | **Tipo:** Ordinal 1-5 + escenarios cubiertos

Pregunta GQM: Q-RS-01

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	3	3	3	2	3	3	25	✓ Recomendada

Justificaciones clave:

- **G=3:** Los playbooks son documentos verificables. Su existencia, contenido y estado de prueba pueden auditarse directamente.
- **M=3:** La pregunta "¿Qué hacemos si un atacante manipula nuestro sistema de IA?" es perfectamente comprensible para la dirección.
- **Ac=3:** El número de escenarios cubiertos y el estado de prueba (no probado / probado en tabletop / probado en ejercicio real) son altamente objetivos.
- **I=3:** Los playbooks son documentos verificables por auditores externos.
- **C=3:** Desarrollar playbooks es relativamente económico. El valor decisional en un incidente real es enorme.

Los 5 escenarios mínimos (Puntuación ≥ 4):

1. Phishing LLM con compromiso de credenciales
2. Deepfake ejecutivo en fraude de transferencia (Business Voice Compromise)
3. Prompt injection en sistema de IA interno
4. Model drift silencioso en sistema de decisión crítica
5. Descubrimiento de Shadow AI con datos sensibles

IGM-RS-02 — Capacidad de análisis forense de sistemas de IA

Marco: NIST IR 8596 RS.AN-03 | **Tipo:** Ordinal 5 categorías

Pregunta GQM: Q-RS-02

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	2	2	2	2	2	2	20	⚠ Condicional

Nota de mejora: El forense específico de IA (análisis de logs de inferencia, reconstrucción de secuencias de prompts, análisis de outputs del modelo) es una disciplina incipiente. La condicionabilidad refleja la escasez de profesionales y herramientas especializadas.

IGM-RS-03 — Conocimiento y aplicación de plazos de notificación IA

Marco: EU AI Act Art. 73; NIS2 Art. 23 | **Tipo:** Ordinal 5 categorías

Pregunta GQM: Q-RS-03

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	3	3	3	3	3	3	26	✓ Recomendada

La puntuación más alta de toda la matriz (26/27). Justificación: Los plazos de notificación son normas legales binarias (se cumplen o no se cumplen), perfectamente comprensibles, altamente accionables (hay que notificar en X horas/días), verificables externamente, y el coste de medición es mínimo. La única limitación es predictividad: el indicador mide conocimiento previo, no garantiza la capacidad operativa en el momento del incidente.

Plazos críticos a conocer (Puntuación 5):

- NIS2 Art. 23: Alerta temprana 24h + notificación 72h + informe final 30 días
- EU AI Act Art. 73: Notificación a AESIA de incidentes graves en 15 días hábiles (sistemas alto riesgo)
- RGPD Art. 33: Notificación AEPD de brechas de datos en 72 horas
- ENS: Coordinación con CCN-CERT según criticidad del sistema

IGM-RS-04 — MTTR-AI: Tiempo medio de respuesta a incidentes IA

Marco: NIST IR 8596 RS.AN-03 | **Tipo:** Temporal 7 rangos

Pregunta GQM: Q-RS-04

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	3	3	3	3	2	3	26	✓ Recomendada

Segunda puntuación más alta de la matriz (26/27). Las métricas temporales como MTTR son las más objetivas, comprensibles y accionables de la ciberseguridad. El único criterio con puntuación 2 es I (Independiente), porque el registro del tiempo de respuesta puede hacerse de forma optimista internamente.

Rangos de valoración:

- 1: MTTR-AI > 72 horas (crítico)
- 2: MTTR-AI 24-72 horas
- 3: MTTR-AI 8-24 horas
- 4: MTTR-AI 4-8 horas
- 5: MTTR-AI 2-4 horas
- 6: MTTR-AI 1-2 horas
- 7: MTTR-AI < 1 hora (excelente, solo con automatización avanzada)

FUNCIÓN RECUPERAR (RC) — 3 Indicadores

IGM-RC-01 — Planes de recuperación con rollback de modelos

Marco: NIST IR 8596 RC.RP-02 (Tier 1) | **Tipo:** Ordinal 1-5

Pregunta GQM: Q-RC-01

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	3	3	2	2	2	2	22	✓ Recomendada

IGM-RC-02 — RTO-AI: Tiempo Objetivo de Recuperación para sistemas de IA

Marco: NIS2 Art. 21.2.c; DORA Art. 24 | **Tipo:** Temporal 6 rangos

Pregunta GQM: Q-RC-02

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
3	3	3	3	3	3	2	2	3	25	✓ Recomendada

Rangos de valoración:

- 1: Sin RTO-AI definido
- 2: RTO-AI > 72 horas
- 3: RTO-AI 24-72 horas
- 4: RTO-AI 8-24 horas
- 5: RTO-AI 4-8 horas
- 6: RTO-AI < 4 horas (validado en ejercicio de recuperación real)

IGM-RC-03 — Revisión de decisiones del sistema comprometido

Marco: EU AI Act Art. 72.1; NIST IR 8596 RC.RP-03 | **Tipo:** Ordinal 5 categorías

Pregunta GQM: Q-RC-03

P	R	A	G	M	Ac	T	I	C	TOTAL	Calificación
2	3	3	3	2	2	2	2	2	21	✓ Recomendada

Resumen Ejecutivo PRAGMATIC

Distribución de Calificaciones

Calificación	Nº de Indicadores	%	Indicadores
✓ Recomendada (≥ 21)	26	89.7%	GV-01 a GV-06, ID-01, ID-02, ID-04, ID-05, PR-01 a PR-06, DE-01, DE-02, DE-03, DE-05, RS-01, RS-03, RS-04, RC-01, RC-02, RC-03
⚠ Condicional (14-20)	3	10.3%	ID-03, DE-04, RS-02
✗ Desestimada (< 14)	0	0%	—

Indicadores con Mayor Puntuación PRAGMATIC

Indicador	Total	Función	Razón del Liderazgo
IGM-RS-03	26	RESPONDER	Plazos normativos: binarios, verificables, altamente accionables
IGM-RS-04	26	RESPONDER	Métrica temporal objetiva, comprensible, con impacto directo
IGM-GV-05	25	GOBERNAR	Función de gobernanza: verificable, genuina, accionable
IGM-RS-01	25	RESPONDER	Playbooks: verificables, comprensibles, coste-eficientes
IGM-RC-02	25	RECUPERAR	RTO-AI: métrica temporal objetiva con impacto directo

Criterios Sistémicamente Bajos (Áreas de Mejora del Marco)

Criterio	Puntuación Media	Análisis
G (Genuino)	2.1/3	Riesgo sistémico de gaming y autoevaluación optimista
I (Independiente)	2.1/3	Alta dependencia de autoevaluación interna
C (Rentable)	2.2/3	Algunos indicadores requieren inversión significativa en herramientas
Ac (Preciso)	2.2/3	Escalas ordinales pueden ser insuficientemente granulares

Documento parte del Kit FAICP 2025-2026 — Versión 1.0 — Abril 2026